DATA CLASSIFICATION QUESTIONNAIRE

WI-001 | Work Instruction | Issued under SOP-001 / POL-001

Document ID: WI-001
Version: 1.0 — DRAFT
Parent SOP: SOP-001 — Data Classification Process
Parent Policy: POL-001 — Data Classification Policy
Classification: Internal Use
Owner: Information Security
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Data Classification Questionnaire
Document ID	WI-001
Version	1.0 — DRAFT
Document Type	Work Instruction — operational tool for use during data asset classification
Parent SOP	SOP-001 — Data Classification Process (Step 3: Classification Assessment)
Parent Policy	POL-001 — Data Classification Policy
Owner	Information Security
How to Use	Complete one questionnaire per data asset. Work through Parts A–C in order. Do not skip questions. The classification output in Part C is the definitive result — record it in the Asset Register per SOP-001 Step 6.

NOTE: This questionnaire applies the highest-applicable-tier rule: a single 'YES' answer in a higher-tier section is sufficient to assign that tier — you do not need to answer 'YES' to every question in a section. Complete all sections regardless, as lower-tier questions identify additional regulatory flags that must be recorded even when the tier is already established by a higher section.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for use

PART A — Asset Identification

Complete all fields before proceeding to classification. This section establishes the scope and context of the asset being classified.

Field	Response
Asset Name / Description	
Asset Type	☐ Dataset / Database ☐ Document / File ☐ Data Stream / Feed ☐ Application Data Store ☐ Physical Records
Business Owner (Data Owner)	
Custodian (System / Storage Owner)	
Date of Classification	
Previous Classification (if reclassification)	
Trigger for this Classification (per SOP-001 §3.1)	☐ New asset created ☐ Asset received from third party ☐ Annual review ☐ Material scope change ☐ System reclassification ☐ Post-incident review ☐ Regulatory change
Brief Description of Data Content	
Where is this data stored / processed?	☐ On-premises ☐ Cloud (provider: _____) ☐ Third-party hosted ☐ Multiple locations
Who has access to this data?	☐ Internal only ☐ Internal + named third parties ☐ Broad external access ☐ Public

PART B — Sensitivity Classification

Work through Sections B1 to B4 in order from highest to lowest tier. Answer every question even if a higher tier is already triggered — lower-tier answers identify regulatory flags that must be recorded in the Asset Register.

IMPORTANT: Highest-applicable-tier rule: the asset's classification is the HIGHEST tier for which at least one 'YES' answer is recorded across all sections. A single YES in B1 classifies the asset as SENSITIVE regardless of all other answers.

B1 — SENSITIVE (Tier 4) Indicators

If YES to any question in this section: classification is SENSITIVE. Continue to B2–B4 for regulatory flag identification.

#	Question	☐ YES	☐ NO	Notes / Regulatory Flag
S1	Does the data include Special Category personal data as defined by GDPR Art. 9? (racial/ethnic origin, political opinions, religious beliefs, trade union membership, genetic data, biometric data, health data, sex life / sexual orientation)			Flag: GDPR Art. 9 — DPIA likely required (SOP-004)
S2	Does the data include Protected Health Information (PHI) as defined under HIPAA? (individually identifiable health information held by a covered entity or business associate)			Flag: HIPAA — BAA required for any third-party processing
S3	Does the data constitute GxP raw data, primary data, or audit trail records from a validated computer system? (batch records, laboratory raw data, clinical trial primary data, electronic audit trail records)			Flag: GxP / 21 CFR Part 11 / EU Annex 11 — ALCOA+ controls apply
S4	Does the data contain unpublished intellectual property, trade secrets, or proprietary formulations whose disclosure would cause material commercial harm?			Flag: IP — legal counsel review recommended
S5	Does the data contain financial data whose unauthorised disclosure could enable fraud, insider trading, or material market impact? (MNPI — material non-public information)			Flag: SOX / Securities law — access restricted to need-to-know
S6	Does the data contain credentials, cryptographic keys, or authentication material that, if compromised, would grant access to Tier 1 systems or GxP data?			Flag: Information Security Critical — PAM controls (POL-009)
S7	Is this data subject to a confidentiality obligation under a regulatory order, court order, or legally binding agreement that prohibits disclosure under any circumstances?			Flag: Legal — Legal review required before any disclosure

	Section B1 Result
→ Tier 4 SENSITIVE?	☐ YES — at least one S1–S7 answer is YES ☐ NO — proceed to B2

B2 — CONFIDENTIAL (Tier 3) Indicators

If YES to any question in this section and no SENSITIVE trigger: classification is CONFIDENTIAL. Continue to B3–B4 for regulatory flags.

#	Question	☐ YES	☐ NO	Notes / Regulatory Flag
C1	Does the data include personal data (any information relating to an identified or identifiable natural person) as defined by GDPR Art. 4(1)? This includes names, email addresses, location data, and online identifiers.			Flag: GDPR — DPA required for any third-party processing (POL-013)
C2	Does the data include personal data of employees, contractors, or job applicants?			Flag: HR / GDPR — access restricted to HR and named roles
C3	Does the data contain detailed financial information below board level — business unit P&L, budget vs actual, supplier pricing, contract values?			Flag: Commercial — NDA required for external access
C4	Is this data shared with a third party under a confidentiality obligation (NDA or contractual restriction)?			Flag: Contract — review sharing obligations before reclassification
C5	Does the data contain detailed security information — network diagrams, vulnerability assessments, penetration test results, or system architecture documents?			Flag: Information Security — restricted to Information Security team
C6	Would unauthorised disclosure of this data cause significant harm to individuals, business operations, or competitive position?			

	Section B2 Result
→ Tier 3 CONFIDENTIAL?	☐ YES — at least one C1–C6 answer is YES ☐ NO — proceed to B3

B3 — INTERNAL USE (Tier 2) Indicators

If YES to any question in this section and no higher-tier trigger: classification is INTERNAL USE.

#	Question	☐ YES	☐ NO	Notes
I 1	Is this data intended for use by [Company Name] employees and authorised third parties only — not for public release?			
I 2	Would disclosure outside [Company Name] cause operational disruption, reputational damage, or minor competitive harm — even if not qualifying as Confidential?			
I 3	Does the data include internal communications (emails, meeting notes, internal reports) not intended for external audiences?			
I 4	Does the data include operational information (process documents, internal procedures, organisational charts) that would be useful to a competitor or threat actor?			

	Section B3 Result
→ Tier 2 INTERNAL USE?	☐ YES — at least one I1–I4 answer is YES ☐ NO — proceed to B4

B4 — PUBLIC (Tier 1) Confirmation

If no higher-tier triggers apply, confirm this data meets the PUBLIC classification standard.

#	Question	☐ YES	☐ NO	Notes
P 1	Is this data already published or intended for public release without restriction?			
P 2	Has the Data Owner explicitly approved this data for unrestricted external access?			PUBLIC classification requires explicit Data Owner approval
P 3	Has Legal / Compliance confirmed no regulatory, contractual, or IP restriction prevents public disclosure?			PUBLIC classification requires Legal confirmation

IMPORTANT: PUBLIC classification requires affirmative YES to P1, P2, and P3. If any answer is NO or unknown, classify as INTERNAL USE minimum. Data that is 'probably fine to share' is not PUBLIC — PUBLIC means explicitly approved for unrestricted external access.

PART C — Classification Output and Regulatory Flags

Complete this section to record the definitive classification result. Transfer all fields to the Asset Register per SOP-001 Step 6.

C1 — Sensitivity Classification Result

	Classification
Assigned Sensitivity Tier	☐ Tier 1: PUBLIC ☐ Tier 2: INTERNAL USE ☐ Tier 3: CONFIDENTIAL ☐ Tier 4: SENSITIVE
Highest-trigger question(s)	(record question IDs e.g. S3, C1): _____
Rationale (brief)	

C2 — Regulatory and Handling Flags

Tick all that apply based on YES answers in Part B. These flags drive additional handling controls and must be recorded in the Asset Register.

Flag	Trigger	Ticked?	Implication
GxP	S3 YES	☐	ALCOA+ controls mandatory. Audit trail protection per POL-014. DIRA register per SOP-003. Validated system controls per POL-006.
GDPR — Standard Personal Data	C1 or C2 YES (but not S1)	☐	Privacy Policy (POL-004) applies. DPA required for any third-party processing. ROPA entry required (SOP-004).
GDPR — Special Category	S1 YES	☐	DPIA required before processing. Explicit consent or Art. 9(2) basis required. Elevated access restriction.
HIPAA / PHI	S2 YES	☐	BAA required for all processors. HIPAA Minimum Necessary rule applies. Breach notification obligations (POL-012/SOP-004).
SOX /	S5 YES	☐	ITGC controls apply. Access restricted to authorised finance

Flag	Trigger	Ticked?	Implication
Financial			roles. Audit trail retained 7 years per POL-002.
21 CFR Part 11	S3 YES (electronic records in FDA-regulated context)	☐	Electronic records and signatures requirements. Audit trail immutability per POL-014. Validated system required per POL-006.
IP / Trade Secret	S4 YES	☐	Legal counsel engaged. NDA required for any access beyond named individuals. Export control assessment if applicable.
MNPI	S5 YES (pre-announcement financial or material information)	☐	Securities law counsel engaged. Access restricted to named insiders list. No external sharing without Legal approval.

C3 — Handling Controls Summary

The following mandatory controls apply based on the classification tier assigned in C1. Confirm each is in place or will be implemented before the data asset is put into active use.

Control	PUBLIC	INTERNAL USE	CONFIDENTIAL	SENSITIVE
Labelling / marking	Not required	Header/footer or file name prefix	Mandatory — "CONFIDENTIAL" marking on all outputs	Mandatory — "SENSITIVE" marking. Physical documents: cover sheet required.
Access control	No restriction	Internal authentication required	Named role or group access. Access review quarterly.	Named individual access only. Access review monthly. MFA mandatory. Logged access.
Encryption at rest	Not required	Recommended	Mandatory	Mandatory — AES-256 minimum
Encryption in transit	Not required	Mandatory (TLS 1.2+)	Mandatory (TLS 1.2+)	Mandatory (TLS 1.3 preferred)
Third-party sharing	Permitted without restriction	NDA or equivalent required	NDA + DPA (if personal data) + explicit Data Owner approval per case	Legal + Data Owner + CISO approval required per case. DPA/BAA mandatory.
Storage location	Any	Approved	Approved corporate	Approved Tier

Control	PUBLIC	INTERNAL USE	CONFIDENTIAL	SENSITIVE
	approved location	corporate systems only	systems only. No personal cloud storage.	1/2 systems only. Location logged. No portable media without encryption and approval.
Disposal	Standard deletion	Secure deletion	Secure deletion + confirmation	Secure deletion + certificate of destruction per POL-002
Retention period	Per POL-002 schedule	Per POL-002 schedule	Per POL-002 schedule + Legal review	Per POL-002 + regulatory requirements (GxP/SOX/HIPAA as applicable)

C4 — Approvals and Asset Register Entry

	Detail
Classification assigned by	_____ (Name / Role)
Date assigned	_____
Data Owner confirmation	☐ Data Owner has reviewed and confirmed this classification
Data Owner signature / approval reference	_____
Information Security review required?	☐ YES — Tier 3/4 classification requires Information Security notification ☐ NO (Tier 1/2)
Information Security reviewed by	_____ (Name) Date: _____
Asset Register entry confirmed	☐ Entry created / updated in Asset Register per SOP-001 Step 6 Reference: _____
Next scheduled review date	_____ (12 months from classification date, or earlier if trigger event occurs)
Notes / exceptions	

GxP: If the classification result is SENSITIVE and the data has any GxP or HIPAA flag: the asset must be formally registered in the relevant regulatory register (DIRA Register under SOP-003 for GxP assets; ROPA under SOP-004 for personal data assets) before the data is used in any regulated process.

— End of Questionnaire —

WI-001 v1.0 DRAFT | [Company Name] | INTERNAL USE